Threat Analysis Report

รายงานวิเคราะห์การโจมตี VMware ESXi ด้วยเทคนิคหลบหนีออกจาก Guest VM

12/01/2026

TLP: CLEAR

สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ
๑๒๐ ชั้น ๗ อาคารซี ศูนย์ราชการเฉลิมพระเกียรติ ๘๐ พรรษา ๕ ธันวาคม ๒๕๕๐
ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพมหานคร ๑๐๒๑๐ อีเมล saraban@ncsa.or.th

สารบัญ

สารบัญ 2
บทสรุปสำหรับผู้บริหาร 3
การวิเคราะห์เชิงเทคนิค 4
Technique Tactics and Procedures (MITRE ATT&CK) 12
Indicator of Compromise (IOCs) 14
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ 15
อ้างอิง (References) 17

บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้วิเคราะห์เหตุการณ์การโจมตีที่มุ่งเป้าไปยังระบบ **VMware ESXi Hypervisor** โดยอาศัยเทคนิค **Virtual Machine Escape** ซึ่งเปิดโอกาสให้โค้ดที่รันอยู่ภายใน Virtual Machine สามารถหลุดออกไปควบคุมระบบโฮสต์ได้โดยตรง เหตุการณ์ดังกล่าวไม่ได้เริ่มต้นจากการโจมตีผ่านช่องโหว่ของ ESXi จากภายนอกเครือข่าย แต่เป็นการโจมตีในลักษณะ *post-compromise* ที่ผู้ไม่หวังดีสามารถเข้าถึงระบบภายในองค์กรได้ก่อนแล้ว ผ่านการใช้**บัญชีผู้ใช้งานที่ถูกต้อง (valid account)** ซึ่งคาดว่าได้มาจากการ compromise ระบบ VPN จากนั้นจึงใช้สิทธิ์ดังกล่าวในการเคลื่อนย้ายภายในเครือข่ายและเข้าควบคุม Virtual Machine เครื่องหนึ่งที่รันอยู่บน ESXi

เมื่อสามารถควบคุม Guest VM ได้แล้ว ผู้ไม่หวังดีจึงเริ่มใช้ประโยชน์จาก **ชุดช่องโหว่ด้านความปลอดภัยของ VMware ESXi** ที่เกี่ยวข้องกับการจัดการหน่วยความจำและการสื่อสารระหว่าง Guest และ Hypervisor ซึ่งทำให้สามารถยกระดับสิทธิ์จากระดับผู้ดูแลระบบภายใน VM ไปสู่ hypervisor และในท้ายที่สุดสามารถควบคุม ESXi kernel ได้อย่างสมบูรณ์ การโจมตีในขั้นนี้ส่งผลกระทบในระดับโครงสร้างพื้นฐาน เนื่องจากเมื่อ ESXi host ถูกยึด ผู้ไม่หวังดีจะสามารถเข้าถึงควบคุมหรือสร้างผลกระทบต่อ Virtual Machine ทั้งหมดที่รันอยู่บนโฮสต์เดียวกันได้ พร้อมทั้งสามารถฝัง backdoor ที่สื่อสารผ่านกลไกเฉพาะของ VMware อย่าง VSOCK ซึ่งยากต่อการตรวจจับด้วยเครื่องมือเฝ้าระวังเครือข่ายทั่วไป

ผลกระทบจากเหตุการณ์ดังกล่าวอาจนำไปสู่การยึดครองระบบอย่างถาวร การรันคำสั่งระบบในระดับ hypervisor การเข้าถึงหรือทำลายข้อมูลของหลายระบบพร้อมกัน รวมถึงการใช้ ESXi เป็นจุดศูนย์กลางในการโจมตีต่อไปยังระบบอื่นภายในเครือข่าย องค์กรที่ใช้งาน VMware ESXi โดยเฉพาะเวอร์ชั่นที่หมดอายุการสนับสนุนหรือยังไม่ได้รับการอัปเดตแพตช์ มีความเสี่ยงสูงต่อการโจมตีในลักษณะนี้ แม้ว่าในปัจจุบัน VMware จะมีการออกแพตช์แก้ไขช่องโหว่ที่เกี่ยวข้องแล้ว แต่เหตุการณ์นี้ตอกย้ำว่า **การจัดการบัญชีผู้ใช้ สิทธิ์การเข้าถึง และการตรวจจับพฤติกรรมหลังการ compromise** เป็นปัจจัยสำคัญไม่แพ้การอุดช่องโหว่ทางเทคนิค องค์กรจึงควรเร่งดำเนินการอัปเดตระบบที่อยู่ในสถานะรองรับ ควบคู่กับการเสริมมาตรการด้าน Identity Security และการเฝ้าระวังพฤติกรรมในระดับ VM และ Hypervisor อย่างรอบด้าน

การวิเคราะห์เชิงเทคนิค

ต้นเหตุของการโจมตี

สาเหตุหลักของการถูกโจมตีนี้เกิดจากการที่ผู้ไม่หวังดีสามารถที่จะ**เข้าถึงเครือข่ายและระบบของเหยื่อได้ด้วยข้อมูล Credential ที่สามารถใช้งานได้จริง**จนถึงการอาศัยประโยชน์จากช่องโหว่ที่นำไปสู่การติดตั้ง Backdoor บนโฮสต์ของ ESXi Hypervisor

เป้าหมายของการโจมตี

เป้าหมายของการโจมตีคือการเข้ายึดเครื่องโฮสต์ของระบบ VMware EXSi โดยใช้เทคนิคการหลบหนีออกไปจาก Guest VM เพื่อติดตั้ง Backdoor, การขโมยข้อมูล และอาจจะนำไปสู่การโจมตีด้วยมัลแวร์เรียกค่าไถ่ (Ransomware)

ผลกระทบ

การโจมตีในลักษณะนี้ส่งผลกระทบในระดับโครงสร้างพื้นฐานขององค์กร เนื่องจากผู้โจมตีสามารถหลบหนีออกจาก Guest Virtual Machine และเข้าควบคุม ESXi hypervisor ได้โดยตรง ทำให้ Virtual Machine ทุกเครื่องที่อยู่บนโฮสต์เดียวกันตกอยู่ภายใต้ความเสี่ยงในการถูกเข้าถึง แก้ไข หรือฝังโค้ดที่เป็นอันตรายโดยไม่ต้องผ่านระบบปฏิบัติการภายใน VM ส่งผลให้เครื่องมือรักษาความปลอดภัยแบบดั้งเดิมไม่สามารถตรวจจับหรือป้องกันได้อย่างมีประสิทธิภาพ นอกจากนี้การฝัง backdoor ระดับ hypervisor และการสื่อสารผ่าน VSOCK ยังทำให้การตรวจสอบและการวิเคราะห์เหตุการณ์ย้อนหลังทำได้ยากยิ่งขึ้น องค์กรอาจเผชิญกับความเสี่ยงด้านการรั่วไหลของข้อมูล การหยุดชะงักของบริการที่สำคัญ ความเสียหายทางการเงิน ตลอดจนผลกระทบต่อความเชื่อมั่นและการปฏิบัติตามข้อกำหนดด้านกฎหมายและกำกับดูแลในวงกว้าง

ขั้นตอนการโจมตี (Attack flow)

1. **Initial access:** ผู้ไม่หวังดีสามารถเข้าถึงเครือข่ายของเหยื่อได้โดยการใช้ credential ที่ถูกต้อง (Valid Credentials) ได้แก่
    a. บัญชี VPN (SonicWall)
    b. บัญชี Domain Admin

    ซึ่ง Credential เหล่านี้เชื่อว่าได้มาจากเหตุการณ์ ข้อมูลรั่วไหล (Data Breach), การทำฟิชชิ่ง (Phishing) หรือวิธีการอื่นที่ยังไม่สามารถยืนยันได้ จากนั้นผู้ไม่หวังดีใช้บัญชีดังกล่าวในการเข้าสู่ระบบเครือข่ายภายในและเครื่อง Guest Virtual Machine (VM) ของเหยื่อโดยไม่ต้องอาศัยการ exploit ช่องโหว่ในขั้นตอน Initial Access

2. **Lateral movement:** หลังจากเข้าสู่ Guest VM ด้วยสิทธิ์ Domain Admin ผู้ไม่หวังดีได้ดำเนินการเคลื่อนย้ายภายในเครือข่าย (Lateral Movement) โดยมีลำดับดังนี้
    a. เชื่อมต่อจาก **Guest VM** ไปยัง **Backup Domain Controller** ผ่าน **Remote Desktop Protocol (RDP)**
    b. ติดตั้งและเรียกใช้งานเครื่องมือสำหรับการสำรวจระบบ (Reconnaissance) ได้แก่
        i. Advanced_Port_Scanner_2.5.3869.exe
        ii. netscan.exe
    c. เรียกใช้งาน ShareFinder เพื่อแสดงรายการ Network Share และบันทึกผลลัพธ์ไว้ที่ **C:\ProgramData\shares.txt**

    จากนั้นผู้ไม่หวังดีใช้บัญชี Domain Admin เดิม เคลื่อนย้ายจาก Backup Domain Controller ไปยัง Primary Domain Controller พร้อมทั้งดำเนินการดังนี้

    - Deploy เครื่องมือสำหรับการโจมตี VMware ESXi
    - ปรับเปลี่ยนการตั้งค่า Windows Firewall เพื่อปิดการเชื่อมต่อออกไปยังเครือข่ายภายนอก (Outbound) แต่ยังคงอนุญาตการสื่อสารภายในเครือข่าย

    พฤติกรรมการปรับ Firewall ในลักษณะนี้มักพบในเหตุการณ์โจมตีจริง เพื่อป้องกันไม่ให้เหยื่อขอความช่วยเหลือจากภายนอกหรือให้ซอฟต์แวร์ความปลอดภัยส่งข้อมูลกลับไปยังผู้ให้บริการ ในขณะที่ผู้ไม่หวังดียังคงสามารถขยายขอบเขตการโจมตีภายในเครือข่ายได้อย่างต่อเนื่อง

3. **Execution:** หลังจากที่ผู้ไม่หวังดีได้เตรียมการต่าง ๆ เสร็จสิ้นแล้ว ผู้ไม่หวังดีได้ดำเนินการใช้งานคำสั่งดังนี้
    a. devcon.exe disable “PCI\VEN_15AD&DEV_0740” เป็นคำสั่งสำหรับปิดการทำงานของ VMware VMCI PCI เพื่อเข้าถึงฮาร์ดแวร์ได้โดยตรง
    b. devcon.exe disable “ROOT\VMWVMCIHOSTDEV” เป็นคำสั่งสำหรับปิดการทำงานของไดร์เวอร์ VMware VMCI host
    c. kdu.exe -prv 1 -map MyDriver.sys เป็นคำสั่งสำหรับใช้ **Kernel Driver Utility (KDU)** สำหรับการบายพาสการบังคับใช้งาน Driver Signature และทำการโหลดไดร์เวอร์ที่ไม่ได้ทำการลงลายเซ็น (Unsigned driver) ลงบนหน่วยความจำของ Kernel
    d. เรียกใช้งาน **exploit.exe** ซึ่งทำหน้าที่เป็น Orchestration binary สำหรับเตรียมสภาพแวดล้อมบนระบบ, Deploy driver สำหรับการโจมตี, ควบคุมลำดับการโจมตี และทำลายร่องรอยหลังการโจมตี

    วัตถุประสงค์หลักของขั้นตอนนี้คือ**การหลบหนีออกจาก Guest VM และติดตั้ง Backdoor บน ESXi Hypervisor**

4. **VM Escape:** การหลบหนีออกจาก VM (VM Escape) อาศัยการทำงานร่วมกันของ Unsigned Kernel Driver และการ exploit ช่องโหว่ VMware ESXi จำนวน 3 รายการ ได้แก่
    a. CVE-2025-22226 (CVSS 7.1) ช่องโหว่ประเภท out-of-bounds read ใน HGFS (Host-Guest File System) ซึ่งเปิดโอกาสให้สามารถรั่วไหลข้อมูลในหน่วยความจำจากโพรเซส VMX
    b. CVE-2025-22224 (CVSS 9.3) ช่องโหว่แบบ *TOCTOU (Time-of-Check to Time-of-Use)* ใน VMCI (Virtual Machine Communication Interface) ที่นำไปสู่ *out-of-bounds write* และสามารถถูกใช้เพื่อรันโค้ดในสิทธิ์ของโพรเซส VMX
    c. CVE-2025-22225 (CVSS 8.2) ช่องโหว่การเขียนข้อมูลแบบกำหนดตำแหน่งได้ (*arbitrary write*) บน ESXi ซึ่งทำให้สามารถหลบหนีออกจาก VMX sandbox ไปสู่ระดับ kernel ได้

โดยไดร์เวอร์ที่ถูกโหลดเข้าไปมีชื่อว่า **MyDriver.sys** โดยภายในไดร์เวอร์จะประกอบไปด้วยฟังก์ชันการทำงานดังนี้

- การสื่อสารกับ VMware ผ่าน Backdoor ของตัวระบบ EXSi เพื่อเก็บข้อมูลที่สำคัญอย่างเช่น เวอร์ชั่นของ ESXi อย่างชัดเจน
- การรบกวนการทำงานของ VMCI เพื่อกระตุ้นและใช้ประโยชน์จากช่องโหว่ที่เกิดขึ้น
- อ่านและเขียนหน่วยความจำของโพรเซส VMX
- Deploy shellcode และ backdoor บน ESXi

หลังจากโหลดไดรเวอร์ **MyDriver.sys** และก่อนการ deploy shellcode ผู้ไม่หวังดีต้องดำเนินการเตรียมการหลายขั้นตอนเพื่อให้สามารถควบคุม execution flow ของ VMX process ได้อย่างแม่นยำ โดยมีขั้นตอนสำคัญดังนี้

- **Host Identification:** ตัวไดร์เวอร์จะตรวจสอบ Version และ Build number ของ ESXi อย่างละเอียดผ่านคำสั่งของ VMware Guest SDK “guestlib.stat.get text session” เพื่อที่จะได้ดำเนินการโจมตีให้ตรงกับ Memory layout ของเวอร์ชั่นนั้น ๆ โดยการดำเนินการของไดร์เวอร์นั้นครอบคลุมตั้งแต่เวอร์ชั่น 5.1 ไปจนถึง 8.0

```
15  mw_memset(Str, 0, 4096);
16  mw_SendGuestRPCCommand("guestlib.stat.get text session", (__int64)Str);
17  mw_EsxiBuildNumber = 0;
18  mw_EsxiVersion = 0;
19  for ( i = 0; i < strlen(Str); ++i )
20  {
21    if ( !mw_EsxiBuildNumber )
22    {
23      v0 = strlen("build-");
24      if ( !(unsigned int)sub_140003EF0(&Str[i], "build-", v0) )
25      {
26        for ( j = strlen("build-") + i;
27              j < strlen(Str) && (unsigned __int8)Str[j] >= 0x30u && (unsigned __int8)Str[j] <= 0x39u;
28              ++j )
29        {
30          mw_EsxiBuildNumber = 10 * mw_EsxiBuildNumber + (unsigned __int8)Str[j] - 48;
31        }
32      }
33    }
34    v1 = strlen("VMware ESX 8.0");
35    if ( (unsigned int)sub_140003EF0(&Str[i], "VMware ESX 8.0", v1) )
36    {
37      v2 = strlen("VMware ESX 7.0");
38      if ( (unsigned int)sub_140003EF0(&Str[i], "VMware ESX 7.0", v2) )
39      {
40        v3 = strlen("VMware ESX 6.7");
41        if ( (unsigned int)sub_140003EF0(&Str[i], "VMware ESX 6.7", v3) )
42        {
43          v4 = strlen("VMware ESX 6.5");
44          if ( (unsigned int)sub_140003EF0(&Str[i], "VMware ESX 6.5", v4) )
45          {
46            v5 = strlen("VMware ESX 6.0");
47            if ( (unsigned int)sub_140003EF0(&Str[i], "VMware ESX 6.0", v5) )
48            {
49              v6 = strlen("VMware ESX 5.5");
50              if ( (unsigned int)sub_140003EF0(&Str[i], "VMware ESX 5.5", v6) )
```

ภาพที่ 1 ฟังก์ชันการตรวจสอบ Version และ Build number ของระบบ ESXi

- **Address leaking:** หลังจากที่ได้เวอร์ชั่นของ ESXi ที่เจาะจงมาแล้ว ในขั้นต่อไปคือการทำให้ข้อมูล Based address ของโพรเซส VMX นั้นรั่วไหลออกมาเพื่อหลบหลีกกระบวนการ ASLR (Address Space Layout Randomization) การรั่วไหลข้อมูลดังกล่าวมีความเกี่ยวข้องกับการเปิดใช้งานความสามารถ **HGFS Drag-and-Drop** ผ่านคำสั่ง “tools.capability.hgfs_server toolbox-dnd 1” ซึ่งเป็นฟังก์ชันสำหรับการแชร์ไฟล์ระหว่าง Guest และ Host ซึ่งสามารถนำไปสู่การรั่วไหลข้อมูลจากโพรเซส **VMX** หลังจากที่ได้ based address ที่ได้มาจากการรั่วไหลของข้อมูลรวมเข้ากับข้อมูล offset ที่ถูกกำหนดไว้เฉพาะของแต่ละเวอร์ชั่นสำหรับการระบุตำแหน่งที่จะสามารถเขียน Shell Code ลงไป VMX Memory ได้

ภายหลังจากได้ข้อมูลหน่วยความจำที่จำเป็นแล้ว ผู้ไม่หวังดีได้จัดเตรียมช่องทางการสื่อสารแบบ **VMware backdoor** ระหว่าง Guest และ Host ผ่าน **I/O port 0x5658** ซึ่งเป็นกลไกพื้นฐานที่ใช้ใน VMware Tools สำหรับฟังก์ชันต่าง ๆ เช่น การแชร์คลิปบอร์ด การลาก–วางไฟล์ และการปรับขนาดหน้าจออัตโนมัติ โดยมีการเปิดใช้งาน backdoor จำนวน 6 ช่องทาง และปิดใช้งานบางช่องทาง ก่อนเข้าสู่ขั้นตอนการเขียน shellcode และ hijack execution flow ของ VMX ในลำดับถัดไป

```
18  Str = (char *)ExAllocatePoolWithTag(NonPagedPool, 0x10000u, (ULONG)"TEST");
19  if ( (unsigned __int64)mw_EsxiVersion < 0x46 )
20    v10 = 50616;
21  else
22    v10 = 50624;
23  mw_SendGuestRPCCommand("SetGuestInfo  7 11111111", 0);
24  mw_SendGuestRPCCommand("SetGuestInfo  7 1", 0);
25  mw_SendGuestRPCCommand("tools.capability.guest_conf_directory tmp", 0);
26  mw_SendGuestRPCCommand("tools.capability.hgfs_server toolbox 0", 0);
27  mw_SendGuestRPCCommand("tools.capability.hgfs_server toolbox-dnd 1", 0);
28  // Open multiple backdoor channels to manipulate heap state
29  mw_BackdoorOpen();
30  v8 = mw_BackdoorOpen();
31  mw_BackdoorOpen();
32  v9 = mw_BackdoorOpen();
33  mw_BackdoorOpen();
34  v4 = mw_BackdoorCmdLow();
35  mw_BackdoorCmdHigh();
36  mw_BackdoorCmdHigh();
37  mw_BackdoorCmdHigh();
38  mw_BackdoorCmdHigh();
39  mw_BackdoorCmdHigh();
40  mw_BackdoorClose(v8);
41  mw_BackdoorClose(v9);                          //
42                                                 // Send initial buffer and toolbox-dnd trigger
43  mw_SendGuestRPCCommand("tools.set.version 1", 0);
44  mw_BackdoorCmdHigh();
45  mw_memset(Str, 0, 0x10000);
46  mw_BackdoorSendData(v4, (unsigned __int8 *)Str, v10 - 24);
47  ReplyLen = mw_BackdoorGetReplyLen(v4);
```

ภาพที่ 2 ฟังก์ชันการเปิดใช้งานช่องทาง VMware backdoor

5. **Writing Shellcode:** ด้วยข้อมูล Address ที่ได้มาจากการรั่วไหล ผู้ไม่หวังดีสามารถที่จะอ่าน เขียน ข้อมูลลงไปยัง VMX Memory ผู้ไม่หวังดีจะทำการสร้างเพย์โหลดลงไปใน VMX Memory ดังนี้
    a. Stage 1 Shellcode
    b. Stage 2 Shellcode
    c. ELF Backdoor (VSOCKpuppet)

    โดยการที่ผู้ไม่หวังดีสามารถที่จะอ่านหรือเขียนโค้ดลงบนหน่วยความจำได้นั้นคาดว่าเกิดขึ้นจากการใช้ประโยชน์ของช่องโหว่ประเภทการนำไปสู่การเขียนที่นอกขอบเขต (Leads to an out-of-bounds write)

    นอกจากผู้ไม่หวังดีจะทำการเขียนเพย์โหลดแล้วยังทำการเขียนทับตัวชี้ฟังก์ชัน (Function pointer) ที่อยู่ภายใน VMX โดยจะบันทึกค่าเดิมเอาไว้ แล้วเขียนทับด้วยค่า Address ของ Shell code ที่ได้ทำการเขียนไว้ลงไปแทน จากนั้นผู้ไม่หวังดีจะส่งค่า VMCI Message ไปที่เครื่องโฮสต์เพื่อเป็นการกระตุ้น VMX เมื่อตัวรับข้อมูลของ VMX ทำงานจะทำการชี้ Address ของ Shell code แทนโค้ดที่ถูกต้อง

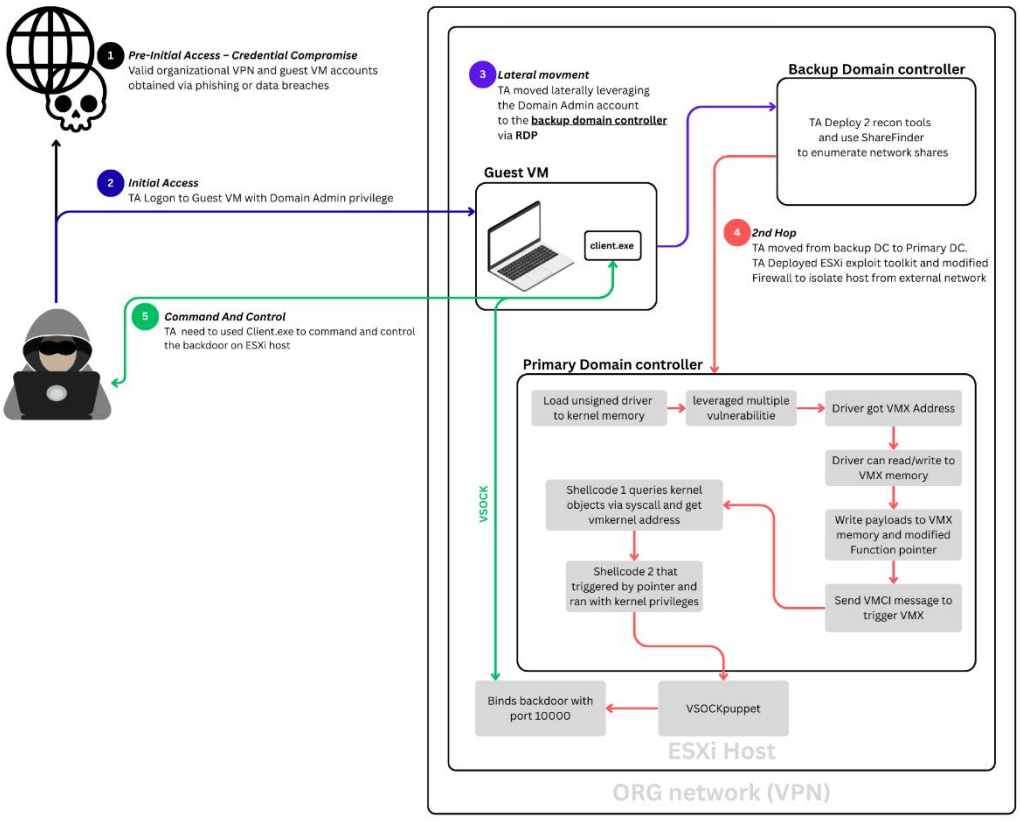
6. **Stage 1 Shellcode:** Shell code ในขั้นแรกนั้นจะทำงานภายใน VMX process และใช้งาน VMkernel syscalls เพื่อค้นหาภายใน kernel internals จากนั้น Shell code จะทำการงานวนลูปเพื่อค้นหาอ็อบเจ็กที่มีชื่อว่า general และค้นหาข้อมูลที่เกี่ยวข้องกับ vmkernel และ vmci เมื่อเจอแล้วจะนำเอา Bassed address ออกมา
7. **Stage 2 Shellcode:** ในขั้นของ Stage 2 shellcode ผู้ไม่หวังดีจะสร้างจุดยึด (foothold) บน ESXi host โดยใช้ system call มาตรฐานของ Linux/Unix เพื่อสร้างไฟล์ backdoor ที่ตำแหน่ง /var/run/a พร้อมกำหนดสิทธิ์แบบเปิดทั้งหมด (0777) และเขียนเพย์โหลด VSOCKpuppet ลงไปในไฟล์ดังกล่าว จากนั้นจะทำการแก้ไขไฟล์กำหนดค่า /var/run/inetd.conf ของบริการ inetd โดยเพิ่มการตั้งค่าสำหรับ hijack พอร์ต 21 (FTP) ให้เรียกใช้งานไฟล์ backdoor ด้วยสิทธิ์ root โดยตรง พร้อมมอบสิทธิ์การเข้าถึงระดับสูงผ่านพารามิเตอร์ ++group=host/vim/vimuser/terminal/ssh เพื่อให้การตั้งค่ามีผลใช้งาน shellcode จะอ่าน process ID ของ inetd จากไฟล์ /var/run/inetd.pid และส่งสัญญาณ SIGHUP เพื่อบังคับให้บริการโหลดคอนฟิกใหม่ ก่อนเชื่อมต่อไปยัง 127.0.0.1:21 ภายในเครื่องเพื่อกระตุ้นให้ backdoor ทำงาน สุดท้าย shellcode จะคืนค่าไฟล์คอนฟิกของ inetd ให้กลับสู่สภาพเดิม เพื่ออำพรางร่องรอยการโจมตี

```
9   strcpy(v4, "/var/run/a");
10  strcpy(v3, "/var/run/inetd.conf");
11  strcpy(v2, "/var/run/inetd.pid");
12  strcpy(v1, "ftp   stream    tcp  nowait   root   /var/run/a   a ++group=host/vim/vimuser/terminal/ssh");
13  __asm { syscall; open("/var/run/inetd.conf") - check if exists }
14  __asm { syscall; close(fd) }
15  __asm { syscall; open("/var/run/a", O_CREAT|O_WRONLY, 0777) - create backdoor file }
16  __asm { syscall; write() - write ELF backdoor to /var/run/a }
17  __asm { syscall; close(fd) }
18  __asm { syscall; open("/var/run/inetd.pid", O_RDONLY) }
19  __asm { syscall; read() - read inetd PID from file }
20  __asm { syscall; close(fd) }
21  __asm { syscall; open("/var/run/inetd.conf", O_RDWR) - read existing content }
22  __asm { syscall; read() - read existing inetd.conf content }
23  __asm { syscall; close(fd) }
24  __asm { syscall; open("/var/run/inetd.conf", O_RDWR) - to append hijack line }
25  __asm { syscall; write() - append FTP hijack line to inetd.conf }
26  __asm { syscall; close(fd) }
27  __asm { syscall; kill(inetd_pid, SIGHUP) - signal inetd to reload config }
28  __asm { syscall; nanosleep() - wait for inetd to reload }
29  __asm { syscall; socket(AF_INET, SOCK_STREAM, 0) - create TCP socket }
30  __asm { syscall; connect(127.0.0.1:21) - trigger backdoor on port 21 }
31  __asm { syscall; nanosleep() - wait }
32  __asm { syscall; close(socket) }
33  __asm { syscall; open("/var/run/inetd.conf") - restore original content }
34  __asm { syscall; write() - restore original inetd.conf (cleanup) }
35  result = 3;
36  __asm { syscall; close(fd) - done }
37  return result;
38 }
```

ภาพที่ 3 ฟังก์การแก้ไขไฟล์ Configuration ของ /var/run/inetd.conf

8. **VSOCKpuppet:** เป็นไฟล์ปฏิบัติการ 64-bit ELF ที่ทำหน้าที่เป็น backdoor เพื่อสร้างการคงอยู่ในระบบและเปิดช่องทาง Remote Access ไปยัง ESXi host โดยอาศัยการสื่อสารผ่าน VSOCK (Virtual Sockets) แทนการใช้เครือข่ายแบบดั้งเดิม ส่งผลให้ทราฟฟิกไม่สามารถถูกตรวจจับได้ด้วยเครื่องมือเฝ้าระวังเครือข่ายทั่วไป เมื่อเริ่มทำงาน backdoor จะตรวจสอบค่า VSOCK address family ผ่านอุปกรณ์ /dev/vsock หรือ /vmfs/devices/char/vsock/vsock และเรียก ioctl VMCI_SOCKETS_GET_AF_VALUE เพื่อดึงหมายเลขโปรโตคอลที่ถูกต้อง จากนั้นจะ bind กับ VSOCK port 10000 โดยใช้ VMADDR_CID_ANY ทำให้ Virtual Machine ใด ๆ บน ESXi host เดียวกันสามารถเชื่อมต่อเข้ามาได้ หลังจากเริ่มทำงาน backdoor จะรอรับ trigger ข้อความ “ok” และสร้างโพรเซสย่อยเพื่อรองรับคำสั่ง 3 รูปแบบ ได้แก่
    a. **GET** สำหรับอ่านไฟล์จาก ESXi
    b. **POST** สำหรับเขียนไฟล์ลงบนโฮสต์
    c. รัน shell command ผ่าน /bin/sh โดยส่งผลลัพธ์กลับไปยังผู้ไม่หวังดี

9. **Command and Control:** หลังจากที่ VSOCKpuppet สามารถที่จะติดต่อระหว่าง Guest VM และ ESXi Host ได้แล้วผู้ไม่หวังดีจะต้องใช้เครื่องมืออีก 1 ตัวสำหรับการส่งคำสั่งไปที่ backdoor ซึ่งอยู่บน ESXi host ผ่านโปรแกรมที่ชื่อว่า **client.exe หรือ GetShell Plugin** บนเครื่อง Guest VM ซึ่งเป็นไคลเอ็นต์ VSOCK บน Windows เพื่อใช้ในการควบคุม Backdoor บน ESXi host



ภาพที่ 4 ภาพแผนภาพการโจมตี

Technique Tactics and Procedures

(MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Initial access	T1078.002	Domain Accounts
	T1133	External Remote Services
Discovery	T1046	Network Service Discovery
	T1135	Network Share Discovery
Execution	T1059.004	Unix Shell
Lateral Movement	T1021.001	Remote Desktop Protocol
	T1021.002	SMB/Windows Admin Shares
Collection	T1560.001	Archive via Utility
	T1074.001	Local Data Staging
Privilege Escalation	T1068	Exploitation for Privilege Escalation
	T1611	Escape to Host
Command And control	T1095	Non-Application Layer Protocol
	T1105	Ingress Tool Transfer
Defense Evasion	T1562.004	Disable or Modify System Firewall
	T1562.001	Disable or Modify Tools

Tactic	Technique ID	Technique Name
	T1211	Exploitation for Defense Evasion

Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

Files Hash (SHA-256)

37972a232ac6d8c402ac4531430967c1fd458b74a52d6d1990688d88956791a7

4614346fc1ff74f057d189db45aa7dc25d6e7f3d9b68c287a409a53c86dca25e

c3f8da7599468c11782c2332497b9e5013d98a1030034243dfed0cf072469c89

dc5b8f7c6a8a6764de3309279e3b6412c23e6af1d7a8631c65b80027444d62bb

2bc5d02774ac1778be22cace51f9e35fe7b53378f8d70143bf646b68d2c0f94c

แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- เฝ้าระวังการใช้งาน **Privileged Accounts** ที่ผิดปกติ เช่น จากเครื่องที่ไม่ควรใช้สิทธิ์สูง, login ข้ามหลายระบบในช่วงเวลาสั้น, Login จากประเทศ/ASN ผิดปกติหรือนอกเวลาที่มีการใช้งานปกติ
- ตรวจจับการใช้งานเครื่องมือที่เข้าข่าย **LOLBins / Admin tools** อย่างเช่น devcon.exe หรือ kdu.exe และควรมีการตั้ง Rule สำหรับการแจ้งเตือนเมื่อมีการ Disable VMware VMCI device/driver หรือมีการโหลดและใช้งาน Unsigned driver
- เฝ้าระวังการเปลี่ยนแปลงไฟล์ Config ต่าง ๆ เช่น inetd.conf, inetd.pid หรือภายในไดเรคทอรี่ /var/run/
- เฝ้าระวังโพรเซสการ Bind **VSOCK port** ผิดปกติ (เช่น port 10000) หรือการเรียกใช้งาน VSOCK

การป้องกัน (Prevention)

- บังคับใช้ MFA สำหรับ VPN และบัญชีผู้ดูแลระบบ เพื่อลดโอกาสที่ผู้ไม่หวังดีจะใช้งานบัญชีที่เกิดการรั่วไหล
- อัปเดตซอฟแวร์: ควรดำเนินการอัปเดตระบบ ESXi ให้เป็นเวอร์ชั่นที่ได้รับการแก้ไขตาม **VMSA-2025-0004** และอัปเดต VMware tools ให้เป็นปัจจุบัน
- หลีกเลี่ยงการใช้งานระบบ ESXi ที่ยกเลิกการสนับสนุนไปแล้ว (EOL)
- จำกัดการใช้งาน VMCI / VSOCK เฉพาะ VM ที่จำเป็นเท่านั้น
- จำกัดการใช้งาน RDP ระหว่าง Guest VM และ Domain Controller

การรับมือ (Response)

- ในกรณีที่พบว่า Guest VM ถูกโจมตีให้ดำเนินการ:
    - แยก VM ออกจากเครือข่าย
    - ทำการ Snapshot ไว้สำหรับการเก็บหลักฐานเพื่อทำ Digital Forensic
    - ตรวจสอบ Loaded driver, Disabled device
    - Reset Credential ที่ถูกใช้งาน
- ในกรณีที่พบว่า ESXi ถูกยึดให้ดำเนินการ:
    - แยก ESXi Host ออกจากเครือข่ายหลักทันที
    - Rebuild ESXi จาก images ที่ได้รับการรับรองว่าปลอดภัย

- Restore VM จาก backup ที่ได้รับการรับรองว่าปลอดภัย
- ดำเนินการ Rotate Credential ทั้งหมดในระบบและดำเนินการใช้งาน MFA
- รายงานเหตุการณ์: แจ้งเหตุการณ์ไปยังหน่วยงานที่เกี่ยวข้องภายในองค์กรและหน่วยงานด้านความมั่นคงปลอดภัยไซเบอร์

อ้างอิง (References)

1. Huntress's Blog "The Great VM Escape: ESXi Exploitation in the Wild"
   https://www.huntress.com/blog/esxi-vm-escape-exploit
2. "China-Linked Hackers Exploit VMware ESXi Zero-Days to Escape Virtual Machines"
   https://thehackernews.com/2026/01/chinese-linked-hackers-exploit-vmware.html
3. CYBLE's Threat Advisory "VMware ESXi Virtual Machine Escape in the Wild"

แบบประเมินรายงานข่าวกรองไซเบอร์

https://dg.th/nsexlfob51

จัดทำโดย

ฤทธิ์นภา ประเสริฐศรี

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน
ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ
โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th